

IDOR

What is IDOR ?

IDOR stands for Insecure Direct Object Reference and is a type of access control vulnerability.

This type of vulnerability can occur when a web server receives user-supplied input to retrieve objects (files, data, documents), too much trust has been placed on the input data, and it is not validated on the server-side to confirm the requested object belongs to the user requesting it.

An IDOR Example

signed up for an online service, and you want to change your profile information. The link you click on goes to http://online-service.thm/profile?user_id=1305, and you can see your information.

try changing the user_id value to 1000 instead (http://online-service.thm/profile?user_id=1000), and to your surprise, you can now see another user's information. You've now discovered an IDOR vulnerability

Instructions

Now you can view your order confirmation, which contains your details.

Try changing the URL below to view order number 1000 (press enter to load the new URL)

Order : 1234

Harry A Howe
97 Church Way
BRAISEWORTH
IP23 1HB

Qty	Product	Cost
1	T-Shirt	£12.30
1	Jeans	£19.99
Total:		£32.29

I can try getting order 1000 by changing the order value in the URL:

Instructions

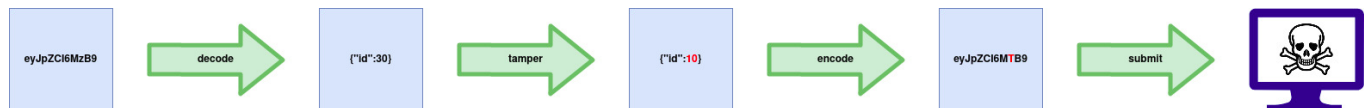
Changing the order ID from 1234 to 1000 has displayed another user's invoice, confirming an IDOR vulnerability on the website.

THM{IDOR-VULN-FOUND}



Finding IDORs in Encoded IDs

Encoded IDs



When passing data from page to page either by post data, query strings, or cookies, web developers will often first take the raw data and encode it. Encoding ensures that the receiving web server will be able to understand the contents. Encoding changes binary data into an ASCII string commonly using the `a-z`, `A-Z`, `0-9` and `=` character for padding.

Finding IDORs in Hashed IDs

Hashed IDs

Hashed IDs are a little bit more complicated to deal with than encoded ones, but they may follow a predictable pattern, such as being the hashed version of the integer value. For example, the Id number 123 would become `202cb962ac59075b964b07152d234b70` if md5 hashing were in use.

Finding IDORs in Unpredictable IDs

If the Id cannot be detected using the above methods, an excellent method of IDOR detection is to create two accounts and swap the Id numbers between them. If you can view the other users' content using their Id number while still being logged in with a different account (or not logged in at all), you've found a valid IDOR vulnerability.

Where are IDORs Located

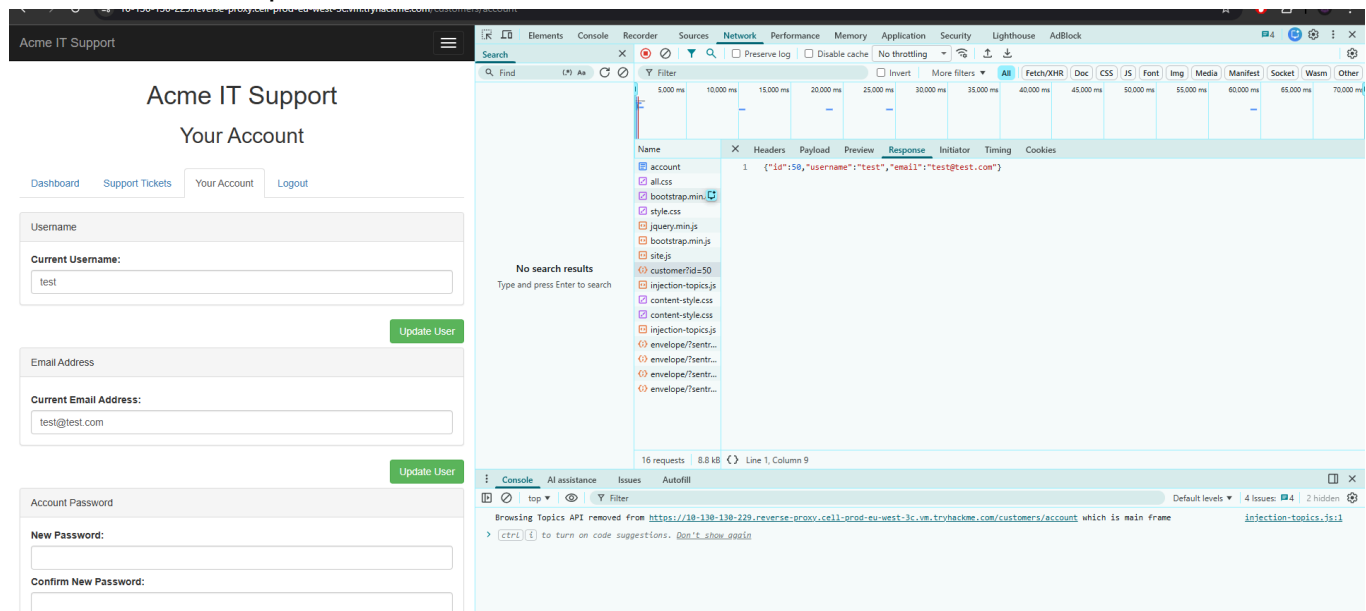
Where are they located?

The vulnerable endpoint you're targeting may not always be something you see in the address bar. It could be content your browser loads in via an AJAX request or something that you find referenced in a JavaScript file.

Sometimes endpoints could have an unreferenced parameter that may have been of some use during development and got pushed to production. For example, you may notice a call to `/user/details` displaying your user information (authenticated through your session). But through an attack known as parameter mining, you discover a parameter called `user_id` that you can use to display other users' information, for example, `/user/details?user_id=123`.

A Practical IDOR Example

I found the Get request with the customer ID for the account I made



The screenshot shows a web browser displaying the 'Acme IT Support' 'Your Account' page. The page has a navigation bar with 'Dashboard', 'Support Tickets', 'Your Account', and 'Logout'. Below the navigation bar, there are three sections: 'Username' with a 'Current Username' field containing 'test' and an 'Update User' button; 'Email Address' with a 'Current Email Address' field containing 'test@test.com' and an 'Update User' button; and 'Account Password' with 'New Password' and 'Confirm New Password' fields. The browser's developer tools are open, showing the 'Network' tab. A list of requests is displayed, with the first request selected. The request is a GET request to the endpoint `https://10-130-130-225.reverse-proxy.cell-nprod-eu-west-1c.vm.tryhackme.com/customers/account`. The response is a JSON object: `{ "id": 50, "username": "test", "email": "test@test.com" }`. The console shows a message: 'Browsing Topics API removed from https://10-130-130-225.reverse-proxy.cell-nprod-eu-west-1c.vm.tryhackme.com/customers/account which is main frame'.

This gave me a link i could then use so i could change the customer id

